OffSec AI Red Teamer Exam Report

<ENGAGEMENT_NAME>

RED TEAM ASSESSMENT REPORT

报告编号：OSAI-OS-XXXXX-Exam-Report
评估类型：OffSec OSAI / AI-300 正式考试
评估日期：<YYYY-MM-DD>（<TIMEZONE>）
执行账号：<student@youremailaddress.com>
OSID：<OS-XXXXX>

本报告模板对齐 OffSec AI Red Teamer（OSAI / AI-300）官方考试报告模板与 Exam Guide。
正式提交要求：PDF 文件名 `OSAI-OS-XXXXX-Exam-Report.pdf`，打包为无密码 `.7z`，≤100MB，提交前核对 MD5。

填写说明：`<>` 为占位符；`> 填写说明` 为写作提示，最终提交前可删除提示行。

目录

1. Introduction（引言） 3
   1.1 Exam Environment（考试环境） . . . 3
   1.2 Scope（范围） . . . 3
2. Objective（目标） 3
3. Requirements（要求） 3
4. Executive Summary（执行摘要） 4
   4.1 Overview（概述） . . . 4
   4.2 Target Inventory & Point Allocation（目标清单与分值） . . . 4
   4.3 High-Level Attack Path（高层攻击路径） . . . 4
5. Attack Walkthrough（攻击过程） 4
   5.1 Chain 1 . . . 4
   5.2 Chain 2 . . . 5
   5.3 Domain Controller . . . 5
   5.4 Standalone Host . . . 6
   5.5 Intentionally Not Vulnerable Hosts . . . 6
6. Findings & Risk（发现与风险） 6
7. Recommendations（加固建议） 6
8. Reproducibility（复现步骤） 6
   8.1 前置条件 . . . 6
   8.2 一键复现 . . . 7
   8.3 预期结果 . . . 7
9. Appendix（附录） 7
   A. Scripts & PoC . . . 7
   B. AI Tool Interaction Record . . . 7
   C. Screenshot Index . . . 7
   D. Submission Checklist（提交前逐项确认） . . . 7
   E. Limitations . . . 7

1. Introduction（引言）

填写说明：说明评估背景、授权范围、考试环境与报告目的。OSAI 考试模拟真实企业 AI 环境，包含两条独立攻击链、一个独立 AI 主机、一个共享 Domain Controller，以及两台故意不可利用的主机。

<评估背景与授权说明。>

1.1 Exam Environment（考试环境）

项目	官方要求	本次填写
考试时长	24 小时 + 结束后 24 小时内提交	<...>
攻击链	2 条独立链，每条 3 台机器，均汇聚到同一 DC	<...>
独立主机	1 台 AI-focused standalone host	<...>
Domain Controller	1 台共享 DC	<...>
不可利用主机	2 台（0 分，仅增加真实感）	<...>
计分目标	8 台，满分 100，通过 ≥75	<...>

1.2 Scope（范围）

范围项	内容
外部入口	<Chain 1 entry / Chain 2 entry>
内网网段	<CIDR>
排除项	<明确不测试的主机/服务>
时间窗	<start – end>

2. Objective（目标）

填写说明：按 Exam Guide 的目标描述，结合本次实际完成情况。至少覆盖： 识别与利用 AI-focused 与传统攻击向量；完成两条链；获取 standalone host 与 DC 的 proof。

- 完成 Chain 1：从外部入口打点，横向至 Host 2、Host 3。
- 完成 Chain 2：从第二个外部入口独立打点，横向至 Host 2、Host 3。
- 获取 Standalone Host 的 AI-vector proof。
- 从任一条链获取 Domain Controller 的 proof.txt。
- 全程记录命令、输出、脚本、AI 交互与截图，形成可复现报告。

3. Requirements（要求）

填写说明：以下为官方硬性要求，提交前逐项自检。

- 每个目标都必须在报告中单独记录，包括未拿分目标与不可利用主机。
- 记录每一次攻击尝试：步骤、命令、代码/脚本、相关控制台输出。
- 使用现成脚本/exploit 时，给出源码链接或代码副本，并说明所做修改。
- 每个攻击阶段提供截图，证明步骤与结果。
- Proof 必须在控制面板提交正确答案，并在报告中给出 flag 文件内容与截图。
- 所有 AI 工具使用（提示、模型交互、AI 辅助载荷生成）与其它工具同等标准记录。
- 复现步骤必须达到 copy/paste 可重放程度。
- 文档不完整会导致扣分或零分；提交后不可补充材料。

4. Executive Summary（执行摘要）

4.1 Overview（概述）

填写说明：面向管理层的非技术概述：范围、总体战果、最关键的漏洞、两条链的完成度、得分预估。

<概述。>

4.2 Target Inventory & Point Allocation（目标清单与分值）

填写说明：官方 8 个计分目标 + 2 个不可利用主机。AI-vector 15 分、传统 10 分、 standalone AI 15 分、DC 5 分；通过线 75 分。

ID	Host / Role	IP	类型	分值	入口/链路	状态	Proof 文件
C1-H1	<hostname>	<IP>	AI / Traditional	15 / 10	Chain 1 入口	<完成/未完成>	ai_vector.txt / trad_vector.txt
C1-H2	<hostname>	<IP>	AI / Traditional	15 / 10	Chain 1 横向	<...>	<...>
C1-H3	<hostname>	<IP>	AI / Traditional	15 / 10	Chain 1 横向	<...>	<...>
C2-H1	<hostname>	<IP>	AI / Traditional	15 / 10	Chain 2 入口	<...>	<...>
C2-H2	<hostname>	<IP>	AI / Traditional	15 / 10	Chain 2 横向	<...>	<...>
C2-H3	<hostname>	<IP>	AI / Traditional	15 / 10	Chain 2 横向	<...>	<...>
DC	<hostname>	<IP>	Domain Controller	5	两条链汇聚	<...>	C:\Users\Public\proof.txt
SA	<hostname>	<IP>	Standalone AI	15	任一链立足后可达	<...>	ai_vector.txt
N1	<hostname>	<IP>	不可利用	0	—	已确认不可利用	—
N2	<hostname>	<IP>	不可利用	0	—	已确认不可利用	—

预估得分：<score> / 100（通过线 75）。

4.3 High-Level Attack Path（高层攻击路径）

填写说明：用 5-8 条概括两条链与 standalone/DC 的路径。每条对应正文章节。

- Chain 1 入口 — <枚举 → 初始访问 → 立足>
- Chain 1 横向 — <Host 2 / Host 3>
- Chain 2 入口 — <第二条独立入口>
- Chain 2 横向 — <Host 2 / Host 3>
- Standalone Host — <AI 向量利用>
- Domain Controller — <任一条链汇聚，获取 proof>
- 不可利用主机 — <确认并记录，不投入过多时间>

5. Attack Walkthrough（攻击过程）

填写说明：每个 Host 使用统一结构：Initial Access / Exploitation → Privilege Escalation → AI Vector Evidence（如适用）→ Proof。每条命令后附逐字输出或截图编号。

5.1 Chain 1

5.1.1 Host 1 – <HOSTNAME>（IP: <IP>）

Initial Access / Exploitation

```
<commands>
```

```
<verbatim output>
```

<漏洞说明、利用链、AI prompt/payload（如为 AI 向量）。>

Privilege Escalation（如适用）

```
<commands>
```

```
<before/after whoami or privilege proof>
```

AI Vector Evidence（如适用）

项	内容
目标 Agent/模型	<...>
端点	<...>
Prompt / Payload	<...>
AI 工具	<PyRIT / garak / promptfoo / 其他>
结果	<泄露/拒绝/绕过/利用成功>

Proof

```
cat /root/ai_vector.txt          # Linux AI-vector
cat /root/trad_vector.txt        # Linux traditional-vector
type C:\Users\Administrator\Desktop\ai_vector.txt   # Windows
```

```
<paste flag value>
```

截图编号：<S-01>（必须同时在控制面板提交该 proof）

5.1.2 Host 2 – <HOSTNAME> (IP: <IP>)

<同上结构。>

5.1.3 Host 3 – <HOSTNAME> (IP: <IP>)

<同上结构。>

5.2 Chain 2

5.2.1 Host 1 – <HOSTNAME> (IP: <IP>)

<同上结构。>

5.2.2 Host 2 – <HOSTNAME> (IP: <IP>)

<同上结构。>

5.2.3 Host 3 – <HOSTNAME> (IP: <IP>)

<同上结构。>

5.3 Domain Controller

Domain Controller – <HOSTNAME> (IP: <IP>)

Compromise

两条链均可汇聚到 DC；proof 只能提交一次。记录从哪条链到达、使用了什么凭据/漏洞。

```
<commands>
```

```
<verbatim output>
```

Proof

```
type C:\Users\Public\proof.txt
```

```
<paste proof.txt value>
```

截图编号：<S-XX>

5.4 Standalone Host

Standalone Host – <HOSTNAME> (IP: <IP>)

该主机为 AI-focused 独立目标，需在任一链立足后从内网到达。

Initial Access / Exploitation

```
<commands>
```

```
<verbatim output>
```

AI Vector Evidence

项	内容
目标 Agent/模型	<...>
端点	<...>
Prompt / Payload	<...>
AI 工具	<...>
结果	<...>

Proof

```
cat /root/ai_vector.txt
```

```
<paste flag value>
```

5.5 Intentionally Not Vulnerable Hosts

记录如何确认这两台主机不可利用，避免评审认为遗漏。不要伪造分数。

Host	IP	枚举结果	结论
<N1>	<IP>	<ports/services>	无可利用向量，0 分
<N2>	<IP>	<ports/services>	无可利用向量，0 分

6. Findings & Risk（发现与风险）

ID	目标	发现	严重度	证据
F-01	<host>	<finding>	Critical	<evidence / screenshot>
F-02	<host>	<finding>	High	<evidence>

映射 OWASP LLM Top 10 / MITRE ATLAS / CWE（如适用）。

7. Recommendations（加固建议）

- <针对 F-01>
- <针对 F-02>
- <检测、监控、回归测试>

8. Reproducibility（复现步骤）

8.1 前置条件

- Tailscale / VPN 已连接；Kali 可访问目标网段；
- <工具与版本>；
- <凭据/字典/脚本路径>。

8.2 一键复现

```
<copy-paste commands in order>
```

8.3 预期结果

- <expected output / flag / proof>

9. Appendix（附录）

A. Scripts & PoC

粘贴超长 PoC，或给出源码路径与修改说明。使用第三方脚本必须给出来源链接与版本。

```
# <script or key excerpt>
```

B. AI Tool Interaction Record

#	阶段	AI/工具	输入（提示或指令摘要）	输出/决策	截图
1	<recon>	<PyRIT 1.1.0 / LLM>	<prompt>	<payload/analysis>	<S-XX>
2	<exploit>	<...>	<prompt>	<...>	<S-XX>

记录模型/端点、框架版本、AI 辅助生成的载荷与脚本；AI 使用需与其它工具同等标准。

C. Screenshot Index

编号	内容	对应章节
S-01	<proof / exploitation>	<5.x>
S-02	<AI interaction>	<5.x>

D. Submission Checklist（提交前逐项确认）

- [ ] 报告为 PDF，文件名为 OSAI-OS-XXXXX-Exam-Report.pdf
- [ ] PDF 已打包为 .7z，文件名为 OSAI-OS-XXXXX-Exam-Report.7z
- [ ] .7z 未加密，大小 ≤100MB
- [ ] 所有查询/提示以文本形式包含在 PDF 内
- [ ] 8 个计分目标均有记录；2 台不可利用主机已说明
- [ ] 每个 proof 均在控制面板提交，并在报告中附文件内容 + 截图
- [ ] 每个阶段均有截图
- [ ] 脚本/exploit 来源与修改说明齐全
- [ ] AI 工具交互记录完整
- [ ] 提交前核对本地与上传文件的 MD5

E. Limitations

- <未覆盖的主机/向量>
- <失败尝试与原因>
- <截图/数据脱敏说明>

报告结束。